

OWASP JUICE SHOP PROJECT



U2: NIVEL DE SEGURIDAD REQUERIDO POR
LAS APLICACIONES

PRACTICA 4: OWASP JUICE SHOP

HECHO POR: IZAN NAVARRO

OWASP JUICE SHOP PROJECT



INDICE

1.INTRODUCCIÓN:	3
2. PRIMERA PARTE (APARTADO GUIADO):.....	3
3. SEGUNDA PARTE:.....	3
3.1. Login Admin (utilizando SQL Injection):.....	3
3.2. Login MC SAFESEARCH:.....	5
3.2.1) Utilizando OSINT.....	5
3.2.2) INTRUDER DE BUPSUITE.....	6
3.3. Login con PASSWORD STRENGTH (usando Intruder):.....	10

1.INTRODUCCIÓN:

Tal y como hemos visto en la teoría OWASP es un proyecto de código abierto dedicado a determinar y combatir las causas que hace que el software sea o pueda llegar a ser inseguro.

OWASP proporciona una serie de proyectos, documentos y herramientas para el desarrollo y mantenimiento de aplicaciones seguras.

Todos los recursos están disponibles en <http://www.owasp.org/>

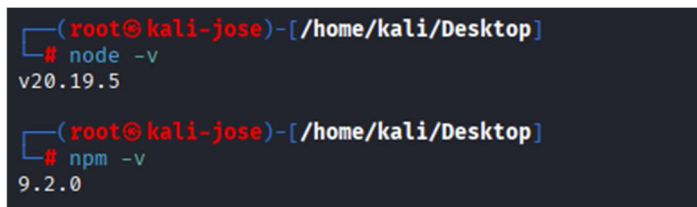
En concreto en esta práctica vamos a utilizar el proyecto Juice Shop para entrenarnos en detectar y corregir las diversas vulnerabilidades que se encuentran en dicha web.

OWASP Juice Shop es probablemente la más moderna y sofisticada insegura la aplicación web. Puede ser utilizada en entrenamientos de seguridad, demos, CTFs y como conejillo de indias para herramientas de seguridad. Juice Shop abarca vulnerabilidades de todo OWASP Top Ten junto con muchas otras seguridades fallas encontradas en aplicaciones del mundo real.

En esta práctica el alumno deberá resolver los retos indicados en la segunda parte de la práctica.

2. PRIMERA PARTE (APARTADO GUIADO):

1) Comprobación de versiones

A terminal window with a dark background. The prompt is '(root@kali-jose)-[/home/kali/Desktop]'. The first command is '# node -v' which outputs 'v20.19.5'. The second command is '# npm -v' which outputs '9.2.0'.

```
(root@kali-jose)-[/home/kali/Desktop]
# node -v
v20.19.5

(root@kali-jose)-[/home/kali/Desktop]
# npm -v
9.2.0
```

3. SEGUNDA PARTE:

3.1. Login Admin (utilizando SQL Injection):

Para este apartado de la práctica he realizado una inyección SQL en la parte del Login del Usuario:

1) Entramos a la interfaz de Juice Shop con el comando "juice-shop -v":

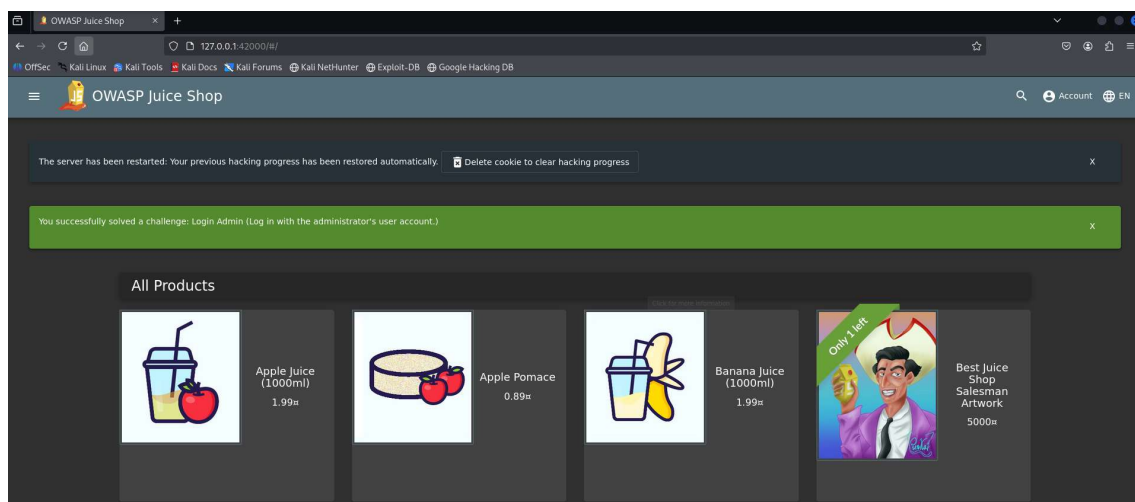
```
(root@kali-jose)-[/home/kali/Desktop]
# juice-shop -v
[*] Please wait for the Juice-shop service to start.
[*] You might need to refresh your browser once it opens.
[*] Web UI: http://127.0.0.1:42000

• juice-shop.service - juice-shop web application
  Loaded: loaded (/usr/lib/systemd/system/juice-shop.service; disabled; preset: disabled)
  Active: active (running) since Fri 2025-12-05 11:05:56 EST; 5s ago
  Invocation: e1355d6aa11947b6925d6d905bd0b004
  Main PID: 3587 (npm start)
    Tasks: 19 (limit: 2208)
  Memory: 65M (peak: 65M)
    CPU: 3.016s
  CGroup: /system.slice/juice-shop.service
          └─3587 "npm start"
            └─3611 sh -c "node build/app"
              └─3616 node build/app

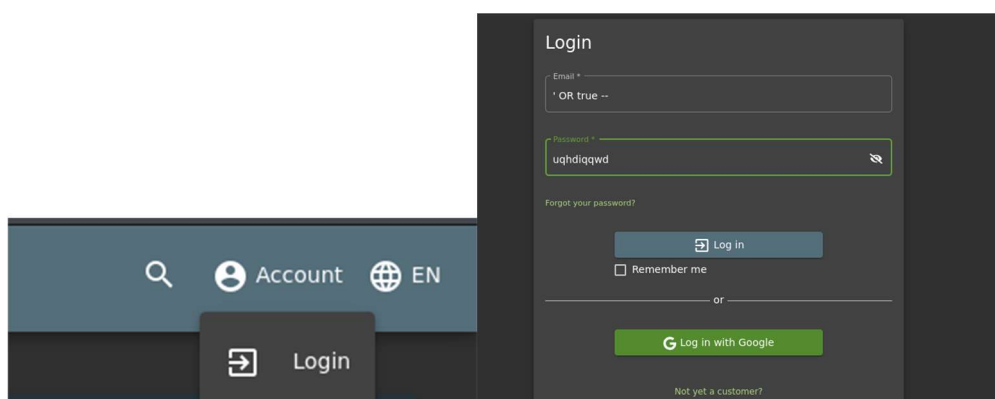
Dec 05 11:05:56 kali-jose systemd[1]: Started juice-shop.service - juice-shop web application.
Dec 05 11:05:58 kali-jose npm[3587]: > juice-shop@16.0.1 start
Dec 05 11:05:58 kali-jose npm[3587]: > node build/app

[*] Opening Web UI (http://127.0.0.1:42000) in: 5 ... 4 ... 3 ... 2 ... 1 ...
```

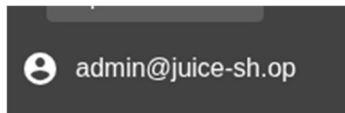
Una vez ejecutado se nos abrirá en el navegador de manera local la pagina web de Juice Shop.



2) Entraremos al apartado de “Account” → Login para poder ejecutar una inyección SQL dentro del campo usuario. La consulta a ejecutar es ‘ OR true – (en el campo usuario). Esta validará dentro de la base de datos que usuario siempre será TRUE y por lo tanto entraremos sin problema:



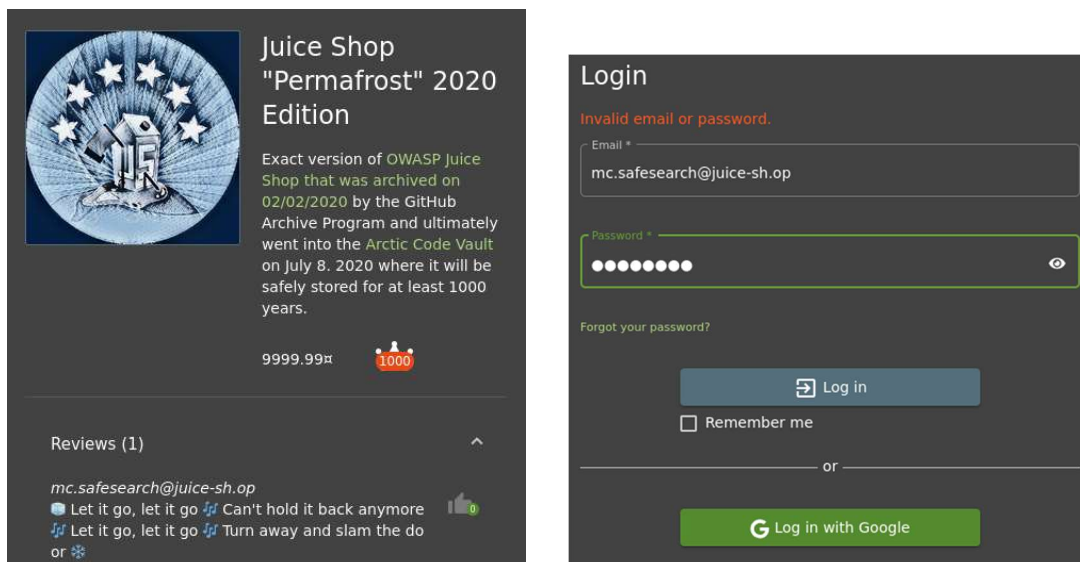
Una vez introducidas estas credenciales lanzaremos una consulta SQL que nos permitirá entrar como administradores:



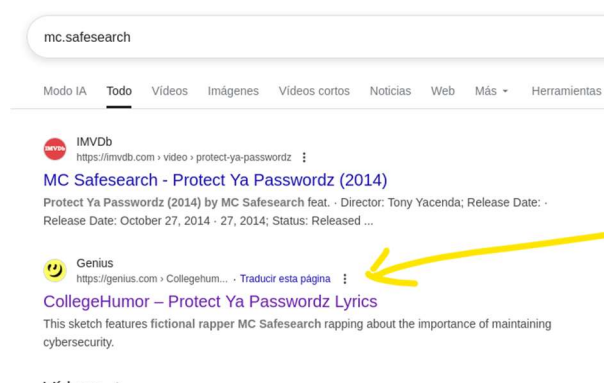
3.2. Login MC SAFESEARCH:

3.2.1) Utilizando OSINT

1) Dentro de la interfaz podremos ver que tenemos productos y una review hecha por el usuario Sefesearch e intentaremos entrar con su email y pwd random y nos dará error:



2) Buscamos el nombre del usuario por el navegador y me salen estas páginas, entramos en Genius.com:

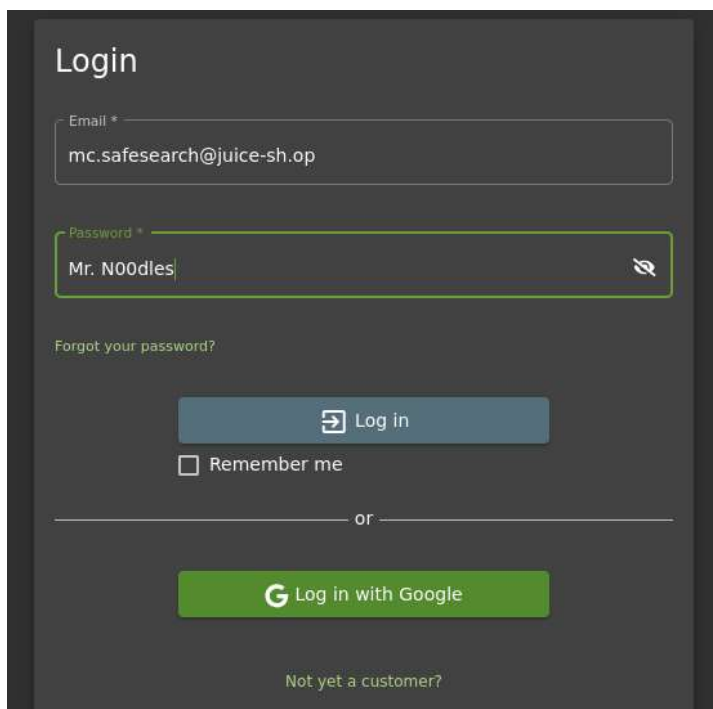


3) Una vez dentro, vemos una canción, nos quedamos con datos personales o gustos del usuario:

[Verse 1: MC Safesearch]
Online, I'm shoppin' and I'm feelin' fine
But I gotta use some passwords to keep what's mine
Passwords are codes that protect yo stuff
You gotta keep them all secret to stay safe enough
"But then how do you remember?" is the question that I get
I say, "Why not use the first name of your favorite pet?"
Mine's my dog, Mr. Noodles. It don't matter if you know
'Cause I was tricky and replaced some vowels with zeroes
I mean, not. You know what? Never mind
That was a general example, not specifically mine
And if you try to log in, you get my username wrong
Wait, did we just show the title at the start of the song?
Aw man, gimme two quick seconds
I mean, I'm not worried, dawg, 'cause I'm password-protected

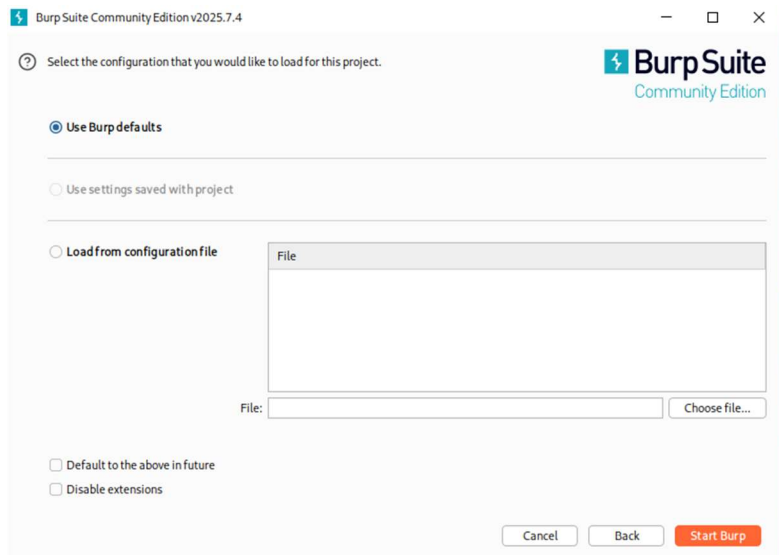
4) Me quedo con Mr. Noodles e intento probar el nombre de mil formas; sin mayúsculas, con minúsculas, con números, con signos... (MR NOODLES, Mr_noodles...). Al final la contraseña era "Mr. N00dles".

You successfully solved a challenge: Login MC SafeSearch (Log in with MC SafeSearch's original user credentials without applying SQL Injection or any other bypass.)

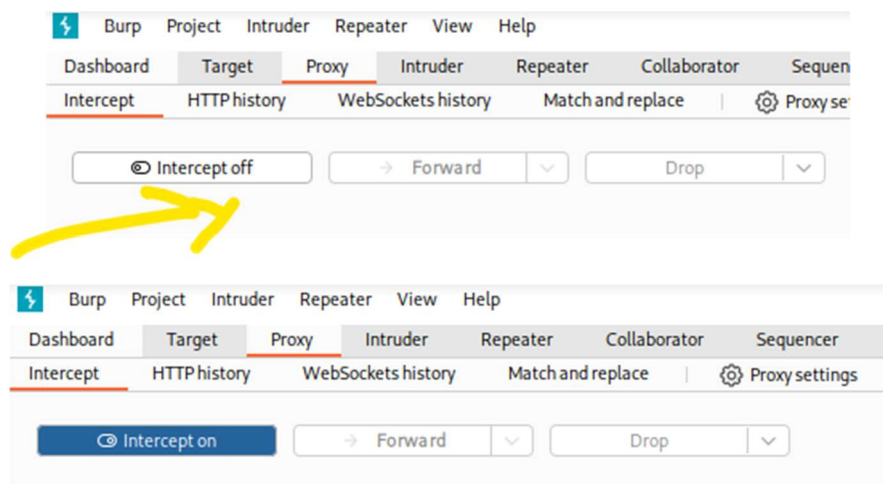


3.2.2) INTRUDER DE BUPSUIITE

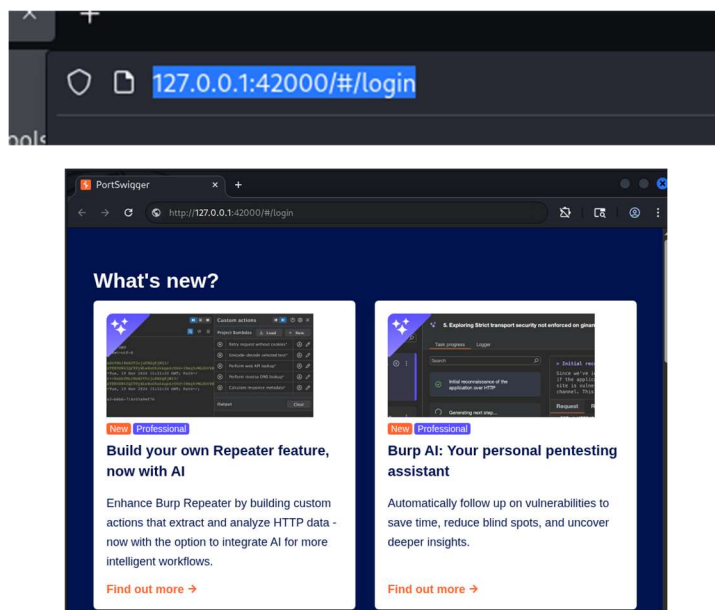
Entramos a burpsuite:



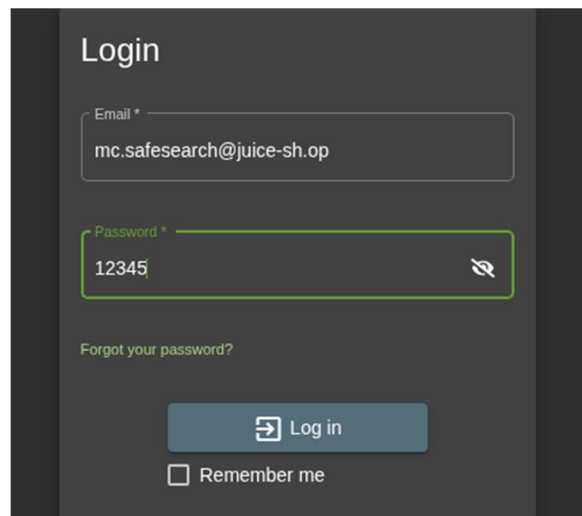
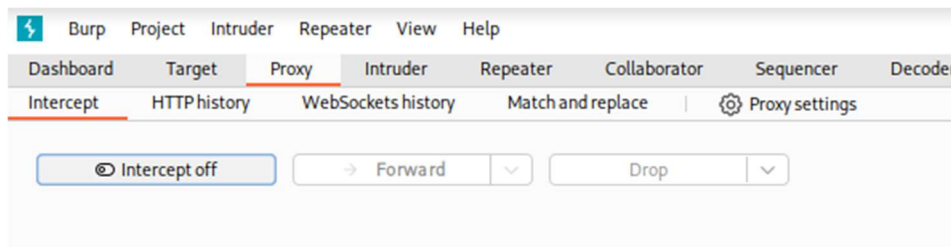
2) Entramos en proxy y ponemos el “Intercept = on”:



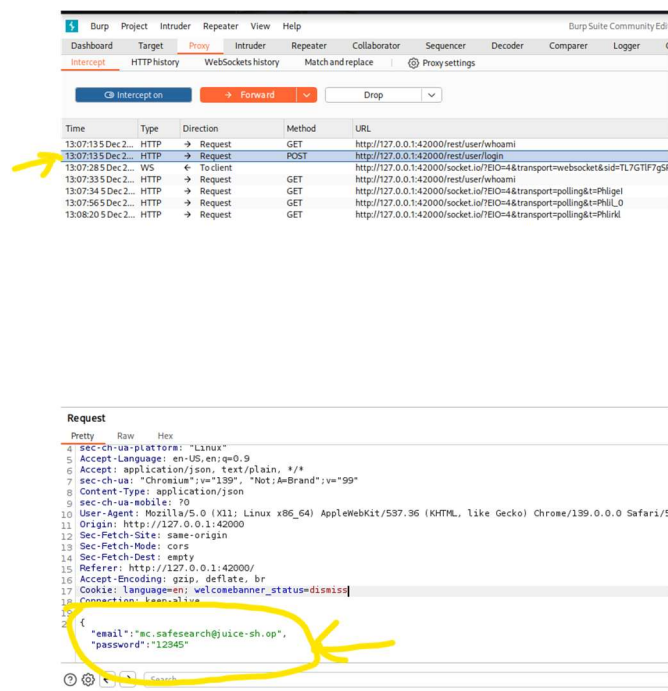
3) Esto nos abre un nuevo navegador para pillar el tráfico de red. Para ello introduciremos en el buscador :



4) Para poder entrar dentro del login de juice-shop, desactivamos el interceptor y nos dejará entrar a la página. Pondremos el correo de mc.safesearch y JUSTO ANTES de darle a Login cogemos y VOLVEMOS A ACTIVAR EL INTERCEPT y entramos de manera muy rápida:

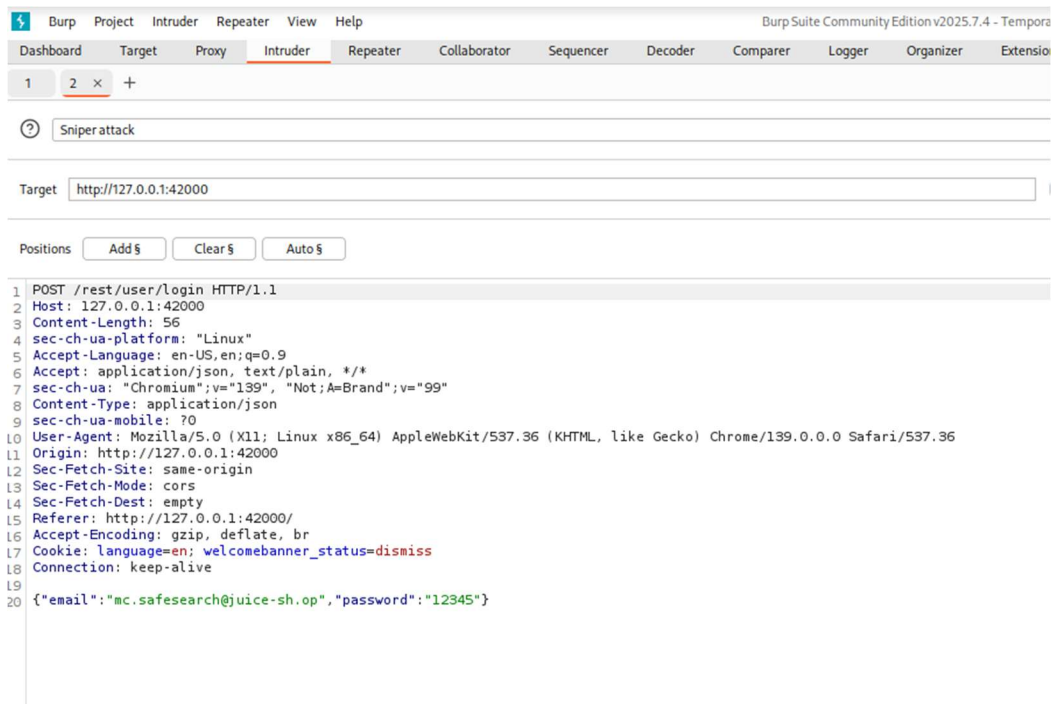


5) Se nos abrirá el burpsuite el cual cogerá el tráfico de la solicitud de entrada login incorrecta:

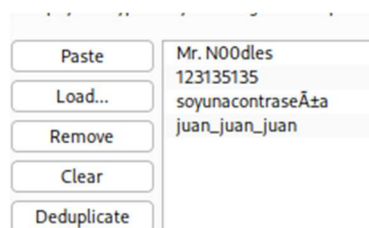
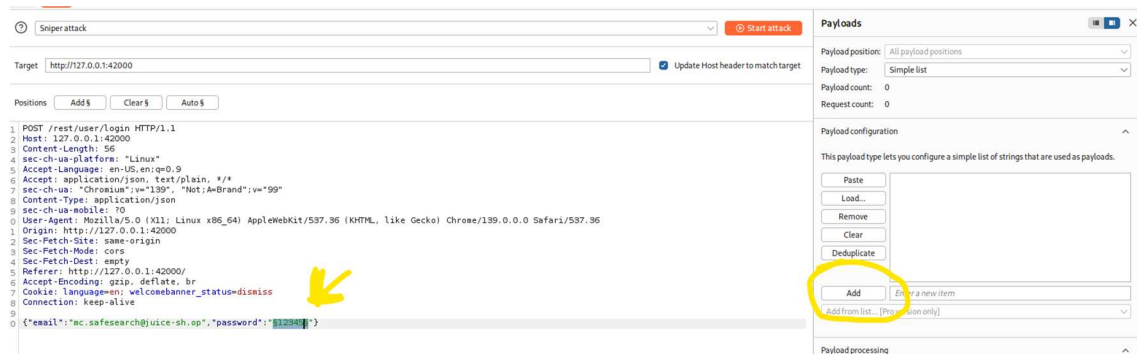


Este se queda con nuestras credenciales introducidas.

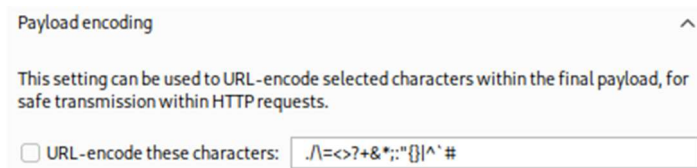
6) Mandamos la petición POST con las credenciales al Intruder:



7) Ahora realizaremos un ataque por fuerza bruta el cual buscaría la contraseña dentro de librerías de contraseñas comunes e intentaríamos entrar. En esta práctica simulada voy a introducir un pequeño txt con diferentes contraseñas (entre ellas la real “Mr. N00dles”) y lo cargaremos.



Desactivamos este checkbox ya que si estuviese activado encriptaría las contraseñas introducidas:



8) Al realizar el Ataque Sniffer de las contraseñas comprobaremos que la contraseña del usuario devolverá **200** y entonces saber con qué contraseña entrar:

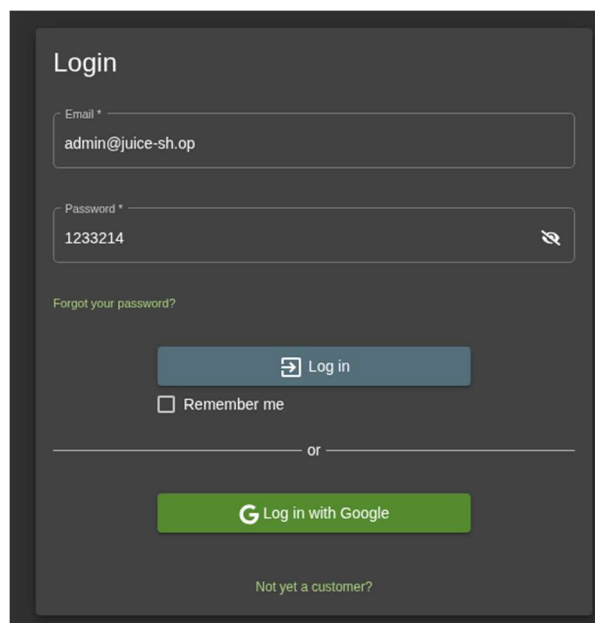
Request	Payload	Status code	Response received	Error	Timeout	Length	Comment
0		401	34			413	
1	Mr: N00di3s	200	726			1213	
2	123135135	401	42			413	
3	soyunacontraseña	401	51			413	
4	juan_juan_juan	401	33			413	

La gracia de esta actividad sería utilizar librerías de contraseñas comunes para poder hacer el testeo real de las contraseñas.

3.3. Login con PASSWORD STRENGTH (usando Intruder):

En esta parte de la práctica volveremos a realizar el mismo proceso que en la parte anterior, pero esta vez intentaremos entrar con usuario: admin y la contraseña la cual haremos con ataques de fuerza bruta.

1) Intentaremos entrar con una contraseña para probar, nos dará error:



2) Captaremos las credenciales introducidas por método POST dentro del Burpsuit:

time	type	Direction	Method	URL
13:38:33 5 Dec 2...	HTTP	→ Request	POST	http://127.0.0.1:42000/rest/user/login
13:38:33 5 Dec 2...	HTTP	→ Request	GET	http://127.0.0.1:42000/rest/user/whoami
13:38:40 5 Dec 2...	WS	← To client		http://127.0.0.1:42000/socket.io/?EIO=4&transport=websocket&sid=cVQnqv9LWN0xbZvnAABZ
13:38:47 5 Dec 2...	HTTP	→ Request	GET	http://127.0.0.1:42000/socket.io/?EIO=4&transport=polling&t=Phlppfi
13:38:53 5 Dec 2...	HTTP	→ Request	GET	http://127.0.0.1:42000/rest/user/whoami
13:39:09 5 Dec 2...	HTTP	→ Request	GET	http://127.0.0.1:42000/socket.io/?EIO=4&transport=polling&t=PhlpvGI
13:39:34 5 Dec 2...	HTTP	→ Request	GET	http://127.0.0.1:42000/socket.io/?EIO=4&transport=polling&t=Phlp_N0

Request

Pretty Raw Hex

```
4 sec-ch-ua-platform: "Linux"
5 Accept-Language: en-US,en;q=0.9
6 Accept: application/json, text/plain, */*
7 sec-ch-ua: "Chromium";v="139", "Not;A=Brand";v="99"
8 Content-Type: application/json
9 sec-ch-ua-mobile: ?0
10 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/139.0.0.0 Safari/537.36
11 Origin: http://127.0.0.1:42000
12 Sec-Fetch-Site: same-origin
13 Sec-Fetch-Mode: cors
14 Sec-Fetch-Dest: empty
15 Referer: http://127.0.0.1:42000/
16 Accept-Encoding: gzip, deflate, br
17 Cookie: language=en; welcomebanner_status=dismiss
18 Connection: keep-alive
19
20 {
21   "email": "admin@juice-sh.op",
22   "password": "1233214"
23 }
```

3) Introduciremos el Método Post en el Intruder, para ello lo mandaremos con “Send Intruder”:

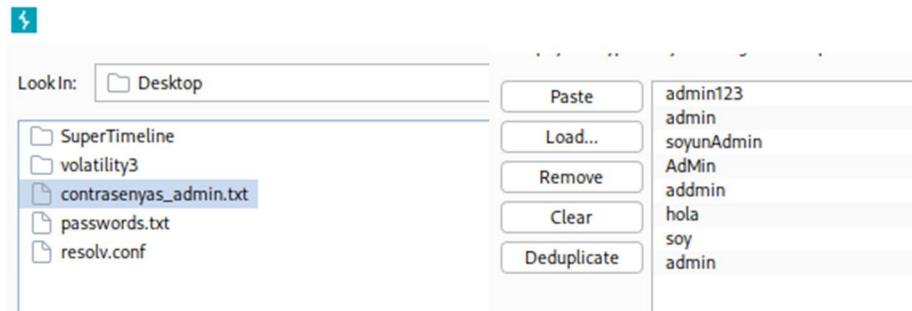
Intercept on Forward Drop

Time	Type	Direction	Method	URL
13:38:33 5 Dec 2...	HTTP	→ Request	POST	http://127.0.0.1:42000/rest/user/login
13:38:33 5 Dec 2...	HTTP	→ Request	GET	http://127.0.0.1:42000/rest/user/whoami
13:38:40 5 Dec 2...	WS	← To client		http://127.0.0.1:42000/socket.io/?EIO=4&transport=websocket&sid=cVQnqv9LWN0xbZvnAABZ
13:38:47 5 Dec 2...	HTTP	→ Request	GET	http://127.0.0.1:42000/socket.io/?EIO=4&transport=polling&t=Phlppfi
13:38:53 5 Dec 2...	HTTP	→ Request	GET	http://127.0.0.1:42000/rest/user/whoami
13:39:09 5 Dec 2...	HTTP	→ Request	GET	http://127.0.0.1:42000/socket.io/?EIO=4&transport=polling&t=PhlpvGI
13:39:34 5 Dec 2...	HTTP	→ Request	GET	http://127.0.0.1:42000/socket.io/?EIO=4&transport=polling&t=Phlp_N0

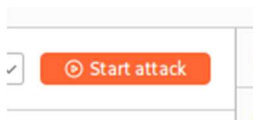
Send to Intruder (Ctrl+I)

4) Generamos el archivo con contraseñas por defecto que se suelen introducir para un admin. En este caso me las invento yo y creo un archivo contrasenyas_admin.txt y LO AÑADIREMOS a Burpsuit.

```
root@kali-jose: /home/kali/Desktop
Session Actions Edit View Help
GNU nano 8.6 contraseñas_admin.txt
admin123
admin
soyunAdmin
AdMin
addmin
hola
soy
admin
```



5) Lanzaremos el ataque:



6) Los resultados incorrectos serán 401 y los resultados correctos devolverán 200:

3. Intruder attack of http://127.0.0.1:42000

Results Positions

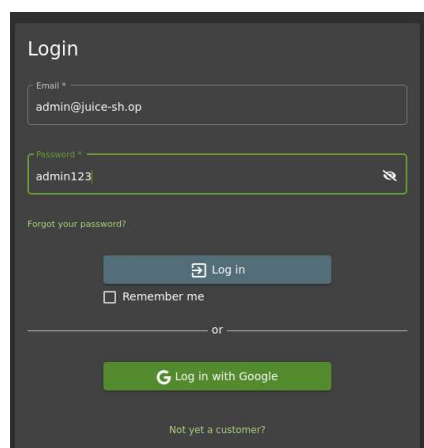
Capture filter: Capturing all items

View filter: Showing all items

Request	Payload	Status code	Response received	Error	Timeout	Length
0		401	728			413
1	admin123	200	3996			1197
2	admin	401	38			413
3	soyunAdmin	401	25			413
4	AdMin	401	67			413
5	addmin	401	20			413
6	hola	401	37			413
7	soy	401	34			413

Vemos que la contraseña “admin123” devuelve 200 y por lo tanto la usaremos para entrar en la cuenta de admin.

7) Entramos con las credenciales y la nueva contraseña.



8) Ya estamos dentro!

